Spell_Casting_101 : Web Exploitation

Creator: Eddie Points: –

Description

The challenger will have to use cross source scripting,“spells,“ to get the website to display the flag. This is from dissecting the code in the dev console where they will see what to call.

Github Path: Capture_The_Flame_2026/Web_Exploit/Spell_Casting_101

Prompt

Welcome to the mandatory spell casting class! In this class, we will cover some of our basic spells that will assist you in your travels. Try going through these spells to see what you can find out about the wonderful world of discovery!

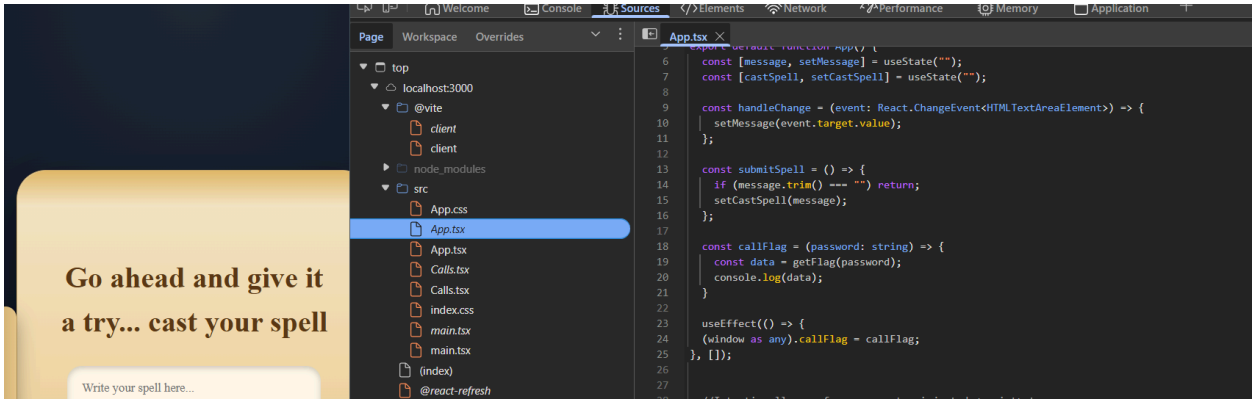
Abracadabra
Alakazam
Shazam
Lumos
Expeliarmus

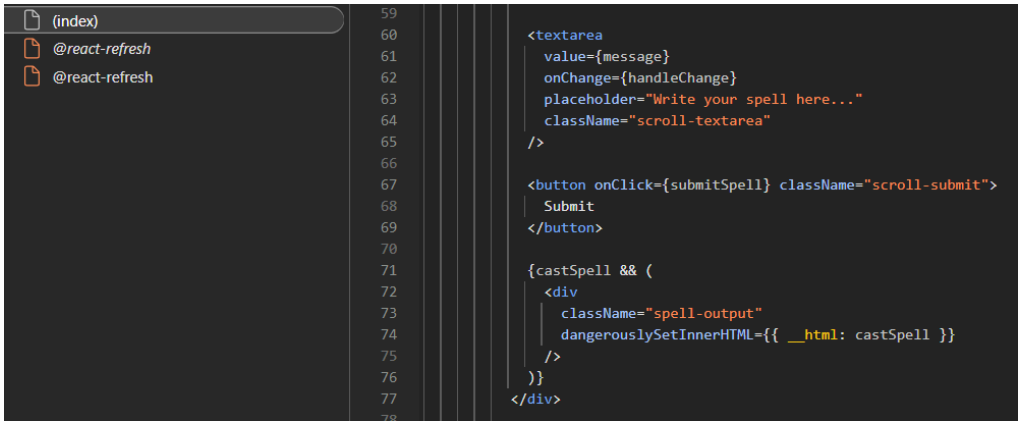
Hints

1. Try pressing F12 and seeing what the code looks like.
2. There’s a way to get the flag from the backend by using the text input on your screen. One of the most dangerous forms of exploits.
3. The professor looks like a size XSS!

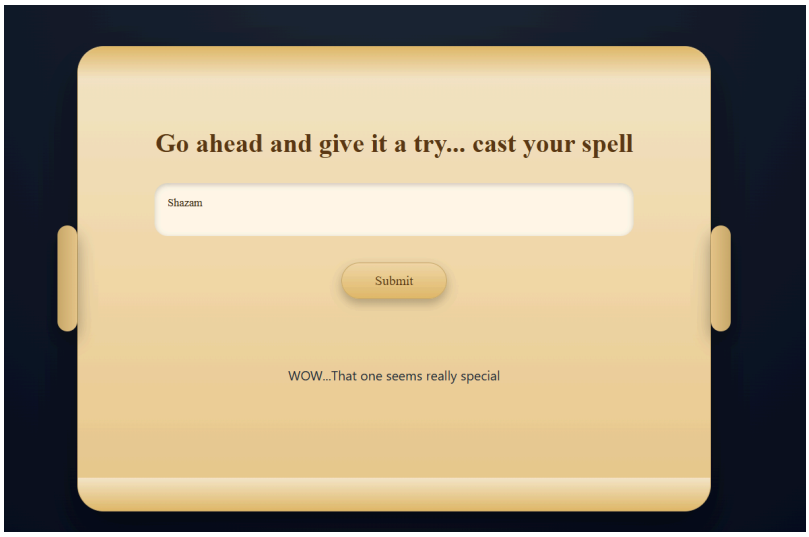
Solution

1. The competitor will have to go to the dev console of the website to see the source code. There they will see a getFlag and get dangerously set HTML which should signal to them that the problem is a Cross Source Scripting approach.





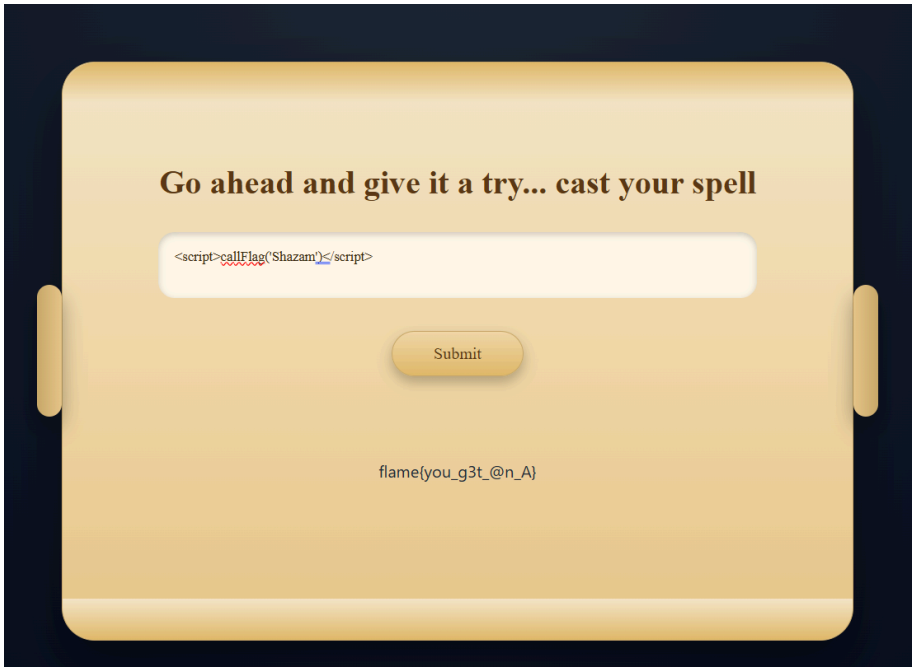
2. From there they will have to go through the list of “spells” given to the user, this will indicate to them that the special spell is “Shazam”



3. Upon inserting the attack into the text area:

<script> callFlag("Shazam") </script>

This will query the backend, call the database and result the flag to the user.



Flag

flame{you_g3t_@n_A}